PROYECTO YURA

Plataforma Web de Gestión Académica

INFORME DE AUDITORÍA COORDINADA CÓDIGO VISUAL + CÓDIGO INTERNO

Informe v1.0

Tipo de documento: Informe de pruebas y auditoría de software

Fecha de emisión: 17 de septiembre de 2026

Versión evaluada: árbol de trabajo actual sobre la rama "develop" (base: commit d419bd0), tras la ronda de correcciones aplicada el mismo día

Repositorio: yura-platform (Laravel 12 · PHP 8.2 · Blade · Vite · MySQL 8)

Metodología: dos subagentes especializados y coordinados (Código Visual + Código Interno) trabajando en paralelo, cruzando hallazgos para evitar duplicados y contradicciones. Cada resultado distingue "probado realmente" de "solo inspeccionado".

ÍNDICE

1. Resumen Ejecutivo
2. Introducción
3. Objetivos
4. Alcance
5. Metodología
6. Arquitectura del Sistema
7. Resultados del Subagente Visual
8. Resultados del Subagente Interno
9. Matriz General de Resultados (cruzada)
10. Hallazgos Críticos y Altos — Detalle
11. Riesgos y Observaciones
12. Plan de Corrección
13. Pruebas Pendientes
14. Conclusiones
15. Recomendaciones
16. Anexos
17. ¿Qué debo corregir? (informe para el estudiante)

RESUMEN EJECUTIVO

Los siguientes indicadores se calcularon a partir de las filas de resultado de los dos subagentes (secciones "Resultados del Subagente Visual" y "Resultados del Subagente Interno"). No incluyen estimaciones ni resultados no verificados.

Indicador	Resultado
Pruebas totales realizadas (ambos subagentes)	53
✅ Aprobadas	28
⚠️ Observaciones	12
❌ Errores	12
⏳ Pendientes	1

Desglose por subagente

Subagente	Total	Aprobadas	Observ.	Errores	Pendientes
Subagente Visual	27	13	8	5	1
Subagente Interno	26	15	4	7	0

Los 6 hallazgos CRÍTICOS de esta ronda (todos probados realmente, no supuestos)

- Api/UserController.php sin ninguna verificación de rol: cualquier usuario autenticado por API puede listar los 25 usuarios completos (PII) y crear una cuenta de administrador nueva — escalación de privilegios total, confirmada creando y eliminando un usuario admin real.
- Exportación masiva de estudiantes (PDF/Excel) sin restricción de rol: un padre descargó realmente el archivo con los 20 estudiantes de la institución.
- Listado /students sin filtrar por rol: un padre real ve a los 20 estudiantes del colegio, no solo al suyo — confirmado de forma independiente por los dos subagentes.
- Login web no valida si el usuario está activo: una cuenta marcada como inactiva pudo iniciar sesión y usar el sistema con normalidad.
- Una comparación de rol escrita como "tutor" literal (en vez de padre/madre/tutor) rompe simultáneamente el dashboard familiar, la ruta /tutor/dashboard y el endpoint de la API para tutores — ningún usuario real del sistema tiene ese rol exacto, así que el 100% de los padres/madres se ve afectado.
- /family-members sin control de acceso por usuario: un padre ve registros familiares de otras familias.

Confirmado que funciona correctamente

- El fix reciente de "Sin curso" en el dashboard del profesor (aplicado tras la ronda anterior) funciona correctamente — verificado de forma independiente por los dos subagentes.
- La suite de pruebas automatizadas (22/22) sigue pasando, pero el Subagente Interno determinó la causa exacta de por qué no detecta ninguno de los 6 hallazgos críticos: los datos de prueba del test existente usan literalmente "rol"=>"tutor" y "estado"=>"activo", los mismos valores erróneos que el código busca, ocultando el problema en vez de exponerlo.

1. INTRODUCCIÓN

Este documento es el "Informe v1.0" de una auditoría coordinada sobre la plataforma web del proyecto YURA (Laravel 12), solicitada expresamente con dos subagentes especializados y complementarios: un Subagente de Código Visual (interfaz, vistas Blade, navegación, experiencia de usuario) y un Subagente de Código Interno (lógica de negocio, controladores, modelos, middleware, autenticación, autorización y su relación con la base de datos real).

A diferencia de auditorías anteriores del proyecto (que usaban tres subagentes divididos por capa técnica: visual, código y configuración), esta ronda agrupa deliberadamente "código" e "interfaz" en dos frentes que se cruzan entre sí: cuando el Subagente Visual detecta que un botón, modal o pantalla depende de una función del servidor, marca el punto explícitamente para que el Subagente Interno lo confirme o lo descarte con una prueba real, evitando hallazgos duplicados o contradictorios entre ambos.

Esta ronda se ejecuta inmediatamente después de una serie de correcciones aplicadas el mismo día (migración de la base de datos a MySQL real, eliminación de un subsistema huérfano de 8 tablas y 6 modelos, eliminación del modelo Tutor, población de la tabla teaching_assignments, corrección de la colisión entre la columna students.course y su relación Eloquent, y consolidación de las columnas users.role/rol). El objetivo es verificar con evidencia real cuáles de esas correcciones funcionan y qué problemas de fondo, antiguos o nuevos, siguen sin resolverse.

2. OBJETIVOS

- Verificar con evidencia real (capturas de pantalla, peticiones HTTP, consultas SQL) el estado de la interfaz y la lógica interna tras la ronda de correcciones más reciente.
- Cruzar los hallazgos de ambos subagentes para identificar duplicados, confirmar sospechas visuales desde el backend, y detectar causas raíz comunes entre síntomas que parecían independientes.
- Cerrar con evidencia definitiva los hallazgos de rondas anteriores que nunca habían sido re-probados con una petición real (exportación masiva, login con usuario inactivo, listado de estudiantes sin scoping).
- Clasificar cada hallazgo por prioridad (crítico, alto, medio, bajo) y distinguir siempre "probado realmente" de "solo inspeccionado".

3. ALCANCE

Incluye: todas las vistas Blade activas y sus rutas correspondientes; los 10 modelos Eloquent vigentes y su correspondencia con la base de datos MySQL real; los controladores web y API; el middleware de autenticación, roles y CSRF; y la suite de pruebas automatizadas existente.

No incluye: pruebas de carga/rendimiento, penetración exhaustiva, ni verificación de hardware físico del robot (fuera del repositorio de la plataforma web).

4. METODOLOGÍA

Ambos subagentes trabajaron en paralelo sobre el mismo estado del proyecto (misma base de datos MySQL real, mismo código fuente), sin modificarlo, distinguiendo en cada fila de sus tablas si el resultado fue "probado realmente" (ejecutando código, tests, curl, tinker, o tomando una captura de pantalla real con Chrome vía Puppeteer) o "solo inspeccionado" (lectura de código sin ejecución).

- Subagente Visual: usó Chrome real (puppeteer-core) con sesiones de navegador aisladas por rol para tomar capturas reales, además de curl con manejo de cookies para pruebas de control de acceso y fuga de datos, y tinker para contrastar lo mostrado en pantalla contra la base de datos real.
- Subagente Interno: usó curl con sesiones autenticadas y tokens Sanctum reales contra un servidor de desarrollo real (php artisan serve) y la base de datos MySQL real, además de consultas SQL directas y la ejecución de la suite de tests.

Cualquier dato de prueba insertado por cualquiera de los dos subagentes (un usuario administrador de prueba, una nota, un cambio temporal de estado) fue revertido explícitamente y verificado al finalizar, según se detalla en cada informe.

5. ARQUITECTURA DEL SISTEMA (estado actual, tras la ronda de correcciones)

- Backend: 10 modelos Eloquent reales (Attendance, Course, Grade, GradeHistory, Parallel, Student, StudentFamilyMember, Subject, TeachingAssignment, User), cada uno confirmado contra una tabla real en MySQL. Ya no existen los modelos huérfanos de rondas anteriores (Activity, ActivitySession, SchoolClass, Group, Interaction, Result, Tutor).
- Base de datos: MySQL 8 real (db_yura_platform), con teaching_assignments ya poblada y la columna users.rol ya eliminada (solo persiste role).
- Autenticación: guard "web" por sesión para el panel, Sanctum (tokens Bearer) para la API. Ambos mecanismos de autenticación funcionan correctamente (probado realmente); los problemas encontrados esta ronda son casi todos de autorización (qué puede hacer un usuario ya autenticado), no de autenticación.
- Interfaz: AdminLTE/Bootstrap con jQuery cargado correctamente en el layout principal; Cuaderno Pedagógico con estructura SER/SABER/HACER; Cursos y Paralelos fusionados en una vista con modales.

6. RESULTADOS DEL SUBAGENTE VISUAL

27 pruebas realizadas, mayormente con capturas de pantalla reales tomadas con Chrome (puppeteer-core) en sesiones de navegador aisladas por rol, complementadas con curl real para pruebas de control de acceso y contraste directo contra la base de datos.

Total	Aprobadas	Observaciones	Errores	Pendientes
27	13	8	5	1

Nº	Elemento	Prueba	Resultado	Probado/Inspeccionado	Estado	Prioridad
1	Login admin/profesor/padre	Login real vía Puppeteer, 3 contextos aislados	Los 3 autentican y redirigen a /dashboard	Probado realmente	✅ APROBADO	—
2	Menú hamburguesa	Clic real, medir clase CSS del body	Colapsa a solo iconos correctamente	Probado realmente	✅ APROBADO	—
3	Dashboard Profesor — curso real en "Top rendimiento"/"Estudiantes asignados"	Login real prof.vargas, extracción DOM	Muestra "Sexto de Primaria" real, no "Sin curso"	Probado realmente	✅ APROBADO	Fix aplicado tras la ronda anterior funciona
4	Mismo fix en las otras 3 ubicaciones del dashboard	Inspección de las 4 líneas del blade	Las 4 usan $student->course()->first()?->name de forma consistente	Probado realmente (3/4) + inspección	✅ APROBADO	—
5	Modal "Lanzar Actividad" del robot — título	Clic real en el modal, es y qu	Sigue mostrando literalmente 'messages.launch_robot_activity'	Probado realmente	❌ ERROR	MEDIO — coincide con hallazgo del Subagente Interno

Nº	Elemento	Prueba	Resultado	Probado/Inspeccionado	Estado	Prioridad
6	Dashboard del rol padre/tutor	Login real juan.quispe (role=padre)	No ve el panel familiar; ve el mensaje "Selección de Curso Requerida" pensado para admin	Probado realmente	❌ ERROR	CRÍTICO — causa raíz: isTutor() compara con role==="tutor" literal
7	Ruta /tutor/dashboard	curl real con cookies de padre	302 con error 'No tienes permisos'	Probado realmente	❌ ERROR	CRÍTICO — misma causa raíz que fila 6
8	Fuga de datos — /students para rol padre	curl real con sesión de padre + verificación en BD	Ve los 20 estudiantes del colegio, no solo su hijo	Probado realmente	❌ ERROR	CRÍTICO — coincide con hallazgo del Subagente Interno
9	Fuga de datos — /family-members para rol padre	curl real con sesión de padre	Ve registros familiares de otras familias, no solo la suya	Probado realmente	❌ ERROR	CRÍTICO — solo confirmado por este subagente
10	Dashboard Admin — tarjetas "Asistencia de Hoy"/"Retos Lanzados"	curl real + contraste con BD	Valores fijos '94%'/'12' (mock hardcodeado en el código), no calculados	Probado realmente	⚠️ OBSERVACIÓN	MEDIO
11	Cursos y Paralelos — modales	Clic real en abrir/cerrar ambos modales	@csrf/required/@error presentes, abren y cierran bien	Probado realmente	✅ APROBADO	—
12	Badge "Secundaria Comunitaria Productiva"	Sin dato de prueba con ese nivel	No verificable visualmente; código correcto por inspección	Solo inspeccionado (sin dato)	⏳ PENDIENTE	—
13	Contador de paralelos/estudiantes por curso	Captura vs conteo real en BD	Coincide exactamente (20 estudiantes)	Probado realmente	✅ APROBADO	—
14	Cuaderno Pedagógico — estructura 24 columnas	Login real, captura completa	Banner y columnas correctos, sin cambios	Probado realmente	✅ APROBADO	—
15	Cuaderno Pedagógico — íconos robot en "Hacer"	Inspección de captura	Ícono con tooltip presente en las 5 columnas	Probado realmente	✅ APROBADO	—
16	Usuarios (/users) — listado vs BD	Login admin, captura + conteo BD	Coincide exactamente por rol y estado	Probado realmente	✅ APROBADO	—
17	Estudiantes (/students) para admin	Login admin, captura	Lista 20 estudiantes con barra de color coherente	Probado realmente	✅ APROBADO	—
18	Vista huérfana auth/register.blade.php	curl a /register	404, sin ruta que la use	Probado realmente	⚠️ OBSERVACIÓN	BAJO
19	Vista huérfana welcome.blade.php	grep de rutas + diff de contenido	No referenciada por ninguna ruta; home.blade.php es la real	Probado realmente	⚠️ OBSERVACIÓN	BAJO
20	Rutas huérfanas /courses/create y /parallels/create	curl real	200 pero sin enlace en la UI	Probado realmente	⚠️ OBSERVACIÓN	BAJO
21	courses/create.blade.php desactualizado	Inspección + intento de envío	Le falta el campo nivel_educativo que el controlador exige	Solo inspeccionado	⚠️ OBSERVACIÓN	BAJO — sin impacto real, vista huérfana
22	Home pública (/)	curl real	200	Probado realmente	✅ APROBADO	—
23	Sidebar — textos sin traducir en Quechua	Cambio real de idioma + captura	6 ítems del menú permanecen en español con qu activo	Probado realmente	⚠️ OBSERVACIÓN	MEDIO
24	Control de acceso — profesor bloqueado de áreas admin	curl real con sesión de profesor	6 rutas admin bloqueadas (302), 3 permitidas (200)	Probado realmente	✅ APROBADO	—
25	Responsive — Mobile (Dashboard/Cursos/Cuaderno)	Capturas reales 375×812	Dashboard/Cursos sin overflow; Cuaderno requiere scroll horizontal (esperado)	Probado realmente	⚠️ OBSERVACIÓN	BAJO — UX preexistente

Nº	Elemento	Prueba	Resultado	Probado/Inspeccionado	Estado	Prioridad
26	Errores de consola JS	Captura de consola durante todo el recorrido admin	Cero errores	Probado realmente	✅ APROBADO	—
27	Estilo inconsistente parallels/edit.blade.php	Inspección de código	Bootstrap plano en vez de la identidad card-quechua	Solo inspeccionado	⚠️ OBSERVACIÓN	BAJO

7. RESULTADOS DEL SUBAGENTE INTERNO

26 pruebas realizadas, casi todas con peticiones HTTP reales (curl con sesiones/tokens reales) contra un servidor de desarrollo real y la base de datos MySQL de producción local, más consultas SQL directas y la ejecución completa de la suite de tests.

Total	Aprobadas	Observaciones	Errores	Pendientes
26	15	4	7	0

Nº	Archivo/Módulo	Prueba	Resultado	Probado/Inspeccionado	Estado	Prioridad
1	10 modelos Eloquent	Schema::hasTable() real para cada uno	Las 10 tablas existen en MySQL real	Probado realmente	✅ APROBADO	N/A
2	app/Models/*.php	Confirmar que solo quedan 10 modelos	Ningún modelo huérfano (Activity/Group/etc. ya no existen)	Probado realmente	✅ APROBADO	N/A
3	User::$fillable vs columnas reales	Comparar contra SHOW COLUMNS	Incluye rol/telefono/estado que ya no existen como columnas, pero los mutators evitan error	Probado realmente	⚠️ OBSERVACIÓN	BAJO
4	Columna users.rol eliminada	SHOW FULL COLUMNS real	Confirmado: solo existe role	Probado realmente	✅ APROBADO	N/A
5	Login admin/profesor tras quitar rol	POST /login real	Ambos exitosos, sesión funcional	Probado realmente	✅ APROBADO	N/A
6	Colisión students.course vs course()	Tinker real sobre Student id=1	course=texto intacto; course()->first()=modelo real	Probado realmente	✅ APROBADO	N/A
7	teaching_assignments poblada	SELECT COUNT(*) real	2 filas, asignación de prof.vargas activa	Probado realmente	✅ APROBADO	N/A
8	POST /grades/save como profesor	Guardado real de nota	200, grade_id creado (y luego eliminado)	Probado realmente	✅ APROBADO	N/A
9	TutorController::myChildren() — GET /api/tutor/my-children	Token real de padre real	403 Unauthorized: exige role==="tutor" y status==="active" literales	Probado realmente	❌ ERROR	CRÍTICO
10	my-children sin token	Petición real sin header	401 correcto	Probado realmente	✅ APROBADO	N/A
11	my-children con token inválido	Petición real con token falso	401 correcto	Probado realmente	✅ APROBADO	N/A
12	Exportación masiva PDF/Excel con rol padre	Descarga real con sesión de padre	200, descarga los 20 estudiantes completos	Probado realmente	❌ ERROR	CRÍTICO
13	GET /students con rol padre	curl real con sesión de padre	Lista los 20 estudiantes, no solo el suyo	Probado realmente	❌ ERROR	CRÍTICO

Nº	Archivo/Módulo	Prueba	Resultado	Probado/Inspeccionado	Estado	Prioridad
14	AuthController::login() con status inactivo	Status cambiado a inactivo en BD real + login real	Login exitoso, sesión plenamente funcional	Probado realmente	❌ ERROR	CRÍTICO
15	CheckRole en /grades, /users, /courses con rol no autorizado	curl real con sesión de padre y profesor	302 en los 3 casos, correcto	Probado realmente	✅ APROBADO	N/A
16	CheckRole en POST /grades/save con rol padre	Sesión real + CSRF válido	302, rechazado correctamente	Probado realmente	✅ APROBADO	N/A
17	CSRF real	POST sin token y con token de otra sesión	419 en ambos casos	Probado realmente	✅ APROBADO	N/A
18	Sanctum — autenticación en 3 endpoints	Con/sin/token inválido	200 con token válido; 401 sin token o inválido	Probado realmente	✅ APROBADO	N/A — ver autorización abajo
19	Api/UserController::index() — GET /api/users	Token real de padre	200, devuelve los 25 usuarios completos con PII	Probado realmente	❌ ERROR	CRÍTICO
20	Api/UserController::store() — POST /api/users	Token real de padre, payload rol=admin	201, creó un usuario admin real (eliminado tras confirmar)	Probado realmente	❌ ERROR	CRÍTICO
21	Api/UserController::toggleStatus()	Mismo patrón, no ejecutado para no alterar datos de terceros	Sin verificación de rol, mismo patrón que 19/20	Solo inspeccionado	⚠️ OBSERVACIÓN	CRÍTICO (mismo patrón)
22	Api/StudentController::index()	GET /api/students con token de padre (incluido en prueba 19)	Devuelve solo 1 estudiante (el correcto) — SÍ filtra bien	Probado realmente	✅ APROBADO	N/A
23	Clave de traducción launch_robot_activity	grep real en es/qu/messages.php	No existe en ninguno de los dos archivos	Probado realmente (archivo)	❌ ERROR	MEDIO — coincide con hallazgo del Subagente Visual
24	Dashboard "rico" para tutores nunca se activa	Inspección + GET /dashboard real como padre	Cae en el branch simple; el rico exige role==="tutor" literal	Probado realmente (no rompe) + inspección	⚠️ OBSERVACIÓN	MEDIO
25	php artisan test (suite completa)	Ejecución real	22/22 pasaron	Probado realmente	✅ APROBADO	N/A
26	Por qué la suite verde no detecta los bugs de autorización	Análisis de tests/Feature/FamilyAndStudentAuthTest.php	El test usa datos ('rol'=>'tutor','estado'=>'activo') que coinciden con el bug, ocultándolo	Probado realmente (análisis del test)	⚠️ OBSERVACIÓN	ALTO

8. MATRIZ GENERAL DE RESULTADOS (cruzada y deduplicada)

Esta matriz consolida los hallazgos accionables de ambos subagentes en una sola vista, agrupando explícitamente los casos donde ambos detectaron el mismo problema de forma independiente ("Detectado por: Visual + Interno") en vez de contarlos dos veces. El detalle exhaustivo de las 53 pruebas realizadas está en las secciones 6 y 7.

Duplicados y causas raíz comunes detectados al cruzar ambos informes

- G-03: el Subagente Visual confirmó en pantalla (curl con sesión real) que un padre ve a los 20 estudiantes en /students; el Subagente Interno llegó exactamente a la misma conclusión de forma independiente, leyendo la causa raíz en StudentController::index(). Mismo hallazgo, contado una sola vez.
- G-05: el Subagente Visual encontró que el dashboard de un padre muestra la pantalla equivocada y que /tutor/dashboard es inalcanzable; el Subagente Interno encontró de forma independiente que el endpoint API my-children rechaza a cualquier tutor real, y que el "dashboard rico" nunca se activa. Las cuatro son la MISMA causa raíz: el código compara el rol contra el literal "tutor" en inglés, pero ningún usuario real de la base de datos tiene ese valor exacto (los reales son "padre"/"madre"). Se agrupan como un solo hallazgo con cuatro síntomas.

- G-08: ambos subagentes, sin coordinarse en el momento, confirmaron independientemente (uno desde la pantalla, otro desde los archivos de idioma) que la clave launch_robot_activity no existe. Mismo hallazgo, contado una sola vez.

ID	Subagente(s)	Área	Hallazgo	Probado/Inspeccionado	Estado	Prioridad
G-01	Interno	API / Autorización	Api/UserController sin ninguna verificación de rol: fuga de PII de 25 usuarios + escalación de privilegios (creación de administradores)	Probado realmente	❌ ERROR	CRÍTICO
G-02	Interno	Autorización / Exportación	Exportación masiva PDF/Excel de estudiantes sin restricción de rol (accesible para padres)	Probado realmente	❌ ERROR	CRÍTICO
G-03	Visual + Interno	Autorización / Datos	Listado /students sin scoping por rol: cualquier padre ve a todos los estudiantes del colegio	Probado realmente (2 subagentes)	❌ ERROR	CRÍTICO
G-04	Interno	Autenticación	Login web no valida si el usuario está activo/inactivo	Probado realmente	❌ ERROR	CRÍTICO
G-05	Visual + Interno	Roles / Causa raíz común	role==='tutor' literal nunca coincide con datos reales (padre/madre): rompe el dashboard familiar, la ruta /tutor/dashboard y el endpoint API my-children	Probado realmente (2 subagentes, 4 síntomas)	❌ ERROR	CRÍTICO
G-06	Visual	Autorización / Datos	/family-members sin scoping por usuario: un padre ve registros de otras familias	Probado realmente	❌ ERROR	CRÍTICO
G-07	Interno	Calidad / Testing	La suite de tests (22/22 verde) no cubre ninguno de los 6 hallazgos críticos de autorización	Probado realmente (análisis)	⚠️ OBSERVACIÓN	ALTO
G-08	Visual + Interno	Interfaz / Internacionalización	Clave de traducción launch_robot_activity ausente en es/qu: el modal del robot muestra texto crudo	Probado realmente (2 subagentes)	❌ ERROR	MEDIO
G-09	Interno	Interfaz / Datos	Dashboard "rico" para tutores nunca se activa con roles reales (mismo patrón de causa raíz que G-05)	Probado realmente	⚠️ OBSERVACIÓN	MEDIO
G-10	Visual	Interfaz / Datos	Dashboard admin con métricas simuladas fijas ('94%', '12') no conectadas a datos reales	Probado realmente	⚠️ OBSERVACIÓN	MEDIO
G-11	Visual	Interfaz / Internacionalización	6 textos del sidebar sin traducir en quechua (agregados en la fusión reciente de Cursos y Paralelos)	Probado realmente	⚠️ OBSERVACIÓN	MEDIO
G-12	Visual	Interfaz / Código muerto	Vistas huérfanas (register, welcome, courses/create, parallels/create) sin impacto en usuario real	Probado realmente	⚠️ OBSERVACIÓN	BAJO
G-13	Visual	Interfaz / Consistencia	courses/create.blade.php desactualizado (falta nivel_educativo); parallels/edit.blade.php con estilo inconsistente	Solo inspeccionado / probado	⚠️ OBSERVACIÓN	BAJO
G-14	Interno	Código / Limpieza	User::$fillable conserva columnas legacy (rol/telefono/estado) inexistentes, sin efecto real	Probado realmente	⚠️ OBSERVACIÓN	BAJO
G-15	Visual	Interfaz / Datos de prueba	Badge "Secundaria Comunitaria Productiva" no verificable visualmente (sin dato de prueba con ese nivel)	Solo inspeccionado	⏳ PENDIENTE	N/A
G-16	Visual + Interno	Confirmación positiva	El fix reciente de "Sin curso" en el dashboard del profesor funciona correctamente (verificado 2 veces)	Probado realmente (2 subagentes)	✅ APROBADO	N/A

9. HALLAZGOS CRÍTICOS Y ALTOS — DETALLE AMPLIADO

Hallazgo G-01 — Api/UserController sin ninguna verificación de rol (fuga de PII + escalación de privilegios) — Prioridad: CRÍTICO

Archivo: app/Http/Controllers/Api/UserController.php, métodos index() (línea 14), store() (línea 23) y toggleStatus() (línea 56). Ruta: routes/api.php líneas 24-27, solo protegidas por auth:sanctum.

Problema: Cualquier usuario autenticado vía API, sin importar su rol, puede listar los 25 usuarios del sistema con datos personales completos, crear un usuario nuevo con CUALQUIER rol (incluido admin), y activar/desactivar la cuenta de cualquier otro usuario.

Reproducción exacta (probada realmente): 1) POST /api/login con juan.quispe@school.bo (rol padre) → token Sanctum. 2) GET /api/users con ese token → 200, devuelve los 25 usuarios. 3) POST /api/users con ese mismo token y body {'rol':'admin', ...} → 201, se crea un usuario

administrador real en la base de datos (id=26, eliminado inmediatamente tras confirmar el hallazgo).

Corrección recomendada: Agregar verificación de rol (equivalente al middleware rol: de las rutas web) a las tres rutas de routes/api.php, restringido a admin únicamente.

Hallazgo G-02 — Exportación masiva de estudiantes sin restricción de rol — Prioridad: CRÍTICO

Archivo: routes/web.php (rutas de exportación PDF/Excel "todos"), StudentController::exportPdfAll() y exportExcelAll().

Problema: Estas rutas solo exigen auth+set.locale del grupo padre; no llevan su propio middleware de rol.

Reproducción exacta (probada realmente): Login como juan.quispe@school.bo (rol padre) → GET /students/export-pdf-all → 200, descarga un PDF de 3 páginas con los 20 estudiantes de la institución; lo mismo con /export-excel-all (XLSX de 7.7 KB).

Corrección recomendada: Agregar ->middleware('rol:admin,academic,profesor') explícitamente a ambas rutas.

Hallazgo G-03 — Listado de estudiantes sin scoping por rol para padres/madres (confirmado por los 2 subagentes) — Prioridad: CRÍTICO

Archivo: app/Http/Controllers/StudentController.php::index(), línea ~39 (único filtro existente: ->when($user->isProfesor(), ...)).

Problema: No existe ninguna condición equivalente para padre/madre/tutor; ven el listado completo sin restricción.

Reproducción exacta (probada realmente por ambos subagentes de forma independiente): Login como juan.quispe@school.bo (rol padre, cuyo único hijo vinculado es "Juan Quispe - 1") → GET /students → se listan los 20 estudiantes del colegio, incluidos alumnos de otras familias.

Corrección recomendada: Agregar un ->when() análogo al que ya funciona correctamente en Api/StudentController::index(), que sí filtra por familiares/parent_user_id.

Hallazgo G-04 — Login web no valida si el usuario está activo — Prioridad: CRÍTICO

Archivo: app/Http/Controllers/AuthController.php::login(), líneas 19-34.

Problema: Auth::attempt() solo verifica email+password; nunca revisa el campo status del usuario.

Reproducción exacta (probada realmente): Se cambió status de un usuario real a 'inactivo' en la base de datos → login con sus credenciales reales → 302 a /dashboard → GET /dashboard devuelve 200 (sesión plenamente funcional). Dato revertido tras la prueba.

Corrección recomendada: Verificar el status inmediatamente después de un Auth::attempt() exitoso, replicando la lógica que ya existe en el login de la API.

Hallazgo G-05 — role==='tutor' literal rompe 4 puntos distintos para el 100% de los padres/madres reales — Prioridad: CRÍTICO

Archivo: app/Models/User.php::isTutor() (línea ~245, compara role==='tutor'); app/Http/Controllers/TutorController.php:92 (my-children); routes/web.php:115 + CheckRole (/tutor/dashboard); app/Http/Controllers/DashboardController.php líneas 35/154 (branch del dashboard).

Problema: Ningún usuario real de la base de datos tiene role='tutor' exacto — los 20 tutores/padres reales tienen role='padre' o 'madre'. Por diseño, el código que debería atenderlos a ellos (el rol 'responsable' de un estudiante) solo se activa con el literal 'tutor', que nadie tiene.

Los 4 síntomas, cada uno probado realmente: 1) Dashboard: un padre real ve el panel pensado para admin ('Selección de Curso Requerida') en vez de su panel familiar. 2) La ruta /tutor/dashboard devuelve 302 con error de permisos para cualquier padre real. 3) GET /api/tutor/my-children devuelve 403 Unauthorized para cualquier padre real con token válido. 4) El 'dashboard rico' (con reporte por hijo) del DashboardController nunca se activa con datos reales.

Corrección recomendada: Usar en los 4 puntos el helper isResponsibleRole() que ya existe en User.php (compara contra ['padre','madre','tutor']), en vez de comparar contra 'tutor' de forma aislada. Extender el middleware de /tutor/dashboard a rol:padre,madre,tutor.

Hallazgo G-06 — /family-members sin control de acceso por usuario — Prioridad: CRÍTICO

Archivo: app/Http/Controllers/FamilyMemberController.php::index(), línea ~14.

Problema: La consulta no filtra por el usuario autenticado en ningún punto.

Reproducción exacta (probada realmente): Login como juan.quispe@school.bo (padre) → GET /family-members → 200, se listan registros de otras familias además de la suya.

Corrección recomendada: Aplicar el mismo criterio de scoping que se recomienda para el hallazgo G-03.

10. RIESGOS Y OBSERVACIONES

Riesgo máximo: exposición y manipulación de datos de menores y del personal

Entre los 6 hallazgos críticos, cuatro implican que un usuario con el nivel de acceso más bajo del sistema (un padre) puede ver datos de estudiantes, familias y personal que no le corresponden, descargarlos en un archivo, y —en el caso de la API de usuarios— hasta crear una cuenta de administrador nueva. Esta combinación (fuga de datos de menores + escalación de privilegios) es el riesgo más severo detectado hasta ahora en cualquier ronda de auditoría de este proyecto.

Riesgo de falsa cobertura de pruebas

La suite automatizada pasa 22/22, pero el Subagente Interno determinó la razón exacta por la que no detecta ninguno de los 6 problemas críticos: el test existente para el rol tutor usa literalmente los mismos valores erróneos ("rol"=>"tutor", "estado"=>"activo") que el código de producción busca, en vez de los valores reales ("padre"/"madre", "activo" en minúsculas con status). Esto significa que la suite verde no es evidencia de que el sistema de roles funcione correctamente para usuarios reales.

Riesgo de mantenimiento por causas raíz compartidas

El hallazgo G-05 demuestra que una sola decisión de diseño (usar el literal "tutor" en inglés) se propagó a al menos 4 puntos distintos del código. Cualquier corrección futura debe aplicarse de forma consistente en los 4 (o centralizarse en el helper isResponsibleRole() ya existente) para no dejar 3 de los 4 arreglados y 1 roto.

11. PLAN DE CORRECCIÓN

No se asignan responsables individuales por no contar con esa información en el repositorio auditado.

Prioridad	Problema	Acción recomendada	Responsable	Estado
CRÍTICO	Api/UserController sin verificación de rol (fuga PII + escalación de privilegios)	Restringir index/store/toggleStatus a rol admin	No asignado	Pendiente
CRÍTICO	Exportación masiva de estudiantes sin restricción de rol	Middleware rol:admin,academic,profesor en las 2 rutas	No asignado	Pendiente
CRÍTICO	Listado /students sin scoping para padre/madre	Replicar el filtro que ya funciona en la API	No asignado	Pendiente
CRÍTICO	Login web no valida usuario inactivo	Verificar status tras Auth::attempt()	No asignado	Pendiente
CRÍTICO	role==='tutor' literal rompe dashboard/ruta/API para todos los padres reales	Usar isResponsibleRole() en los 4 puntos identificados	No asignado	Pendiente
CRÍTICO	/family-members sin control de acceso por usuario	Aplicar el mismo scoping que en /students	No asignado	Pendiente
ALTO	Suite de tests no detecta los 6 problemas críticos	Corregir los datos de prueba del test de tutor y añadir casos para los 6 hallazgos	No asignado	Pendiente
MEDIO	Clave de traducción launch_robot_activity faltante en es/qu	Agregar la clave a ambos archivos de idioma	No asignado	Pendiente
MEDIO	Dashboard admin con métricas simuladas (94%, 12)	Calcular desde Attendance/Grade reales o marcar explícitamente como demo	No asignado	Pendiente
MEDIO	6 textos del sidebar sin traducir en quechua	Envolver con __() en layouts/app.blade.php	No asignado	Pendiente
BAJO	Vistas huérfanas (register, welcome, courses/create, parallels/create)	Eliminar o re-enlazar desde la UI	No asignado	Pendiente
BAJO	courses/create.blade.php desactualizado; parallels/edit.blade.php con estilo inconsistente	Actualizar el formulario o eliminar la vista huérfana; unificar estilo	No asignado	Pendiente
BAJO	User::\$fillable con columnas legacy inexistentes	Limpiar el arreglo $fillable	No asignado	Pendiente

12. PRUEBAS PENDIENTES

Prueba no realizada	Motivo
Verificación visual del badge "Secundaria Comunitaria Productiva"	No existe ningún curso con ese nivel en los datos sembrados; el código es correcto por inspección pero no se pudo confirmar en pantalla
Api/UserController::toggleStatus() — ejecución real del patrón de falta de autorización	No se ejecutó para no alterar el estado de cuentas de terceros sin necesidad, dado que el mismo patrón ya quedó confirmado con index()/store() en el mismo controlador
Ampliación de la suite de tests con casos para los 6 hallazgos críticos	Corresponde a una fase de corrección posterior a este informe, no a la auditoría misma

13. CONCLUSIONES

La coordinación entre los dos subagentes resultó en hallazgos más sólidos que una revisión aislada: el problema del rol "tutor" literal, que en rondas anteriores se había registrado solo como una observación cosmética sobre un ítem de menú, se reveló esta vez como una causa raíz que rompe 4 superficies distintas del sistema (dashboard, una ruta completa, y un endpoint de API), gracias a que ambos subagentes llegaron a la misma causa por caminos independientes (uno desde la pantalla, otro desde el código) y sus hallazgos se cruzaron en este informe.

El hallazgo más grave de toda la auditoría —la API de usuarios sin ninguna verificación de rol, que permite a cualquier padre autenticado crear una cuenta de administrador— no estaba en el radar de ninguna ronda anterior; apareció porque el Subagente Interno probó sistemáticamente cada endpoint de la API en vez de asumir que, por estar ya protegido con Sanctum, estaba seguro.

Los tres hallazgos críticos heredados de rondas anteriores (exportación masiva, login sin validar estado, listado sin scoping) fueron finalmente cerrados con evidencia real y definitiva en esta ronda: los tres siguen fallando exactamente como se sospechaba, sin ambigüedad.

La suite de pruebas automatizadas (22/22) sigue siendo una base de calidad de código razonable para la lógica que sí cubre, pero este informe demuestra con evidencia concreta que "tests en verde" no equivale a "sistema de roles seguro" en este proyecto.

14. RECOMENDACIONES

- Tratar los 6 hallazgos CRÍTICOS como bloqueantes para cualquier despliegue a producción o demostración frente a usuarios reales, dado que exponen datos de menores y permiten escalación de privilegios.
- Corregir primero G-01 (API de usuarios) y G-05 (causa raíz del rol tutor), por ser los de mayor superficie de impacto.
- Añadir a la suite de tests casos que reproduzcan exactamente los 6 hallazgos críticos con los valores reales de rol/estado (no los literales en inglés que ocultan el problema hoy).
- Mantener la práctica de coordinar subagentes especializados que se crucen entre sí: en esta ronda permitió encontrar una causa raíz compartida entre 4 síntomas que, vistos por separado, podrían haberse tratado como 4 arreglos independientes e incompletos.
- Revisar si el helper isResponsibleRole() de User.php debe convertirse en el único punto de verdad para "es un padre/madre/tutor responsable de un estudiante", reemplazando las comparaciones sueltas contra role==="tutor" en todo el código.

15. ANEXOS

Anexo A — Informes íntegros de cada subagente: reproducidos en las secciones 6 y 7 de este documento (27 y 26 filas respectivamente).

Anexo B — Informes de auditoría anteriores del proyecto: docs/pruebas/Informe_YURA_Auditoria_Pruebas.docx/.pdf (rondas 1 y 2) y docs/pruebas/Informe_Auditoria_Base_de_Datos_YURA.docx/.pdf.

Anexo C — Credenciales de prueba usadas (ya públicas en README_EQUIPO.md, contraseña común "password123"): admin@yura.com, gestion.yura@school.bo, prof.vargas@school.bo, prof.flores@school.bo, y tutores/padres con formato {nombre}.{apellido}@school.bo (ej. juan.quispe@school.bo). No se reproducen tokens de API completos ni el usuario administrador creado durante la prueba de escalación de privilegios (fue eliminado inmediatamente tras confirmar el hallazgo).

¿QUÉ DEBO CORREGIR?

Esta sección explica los 6 hallazgos críticos en lenguaje simple, en el orden en que deberías corregirlos.

CORREGIR PRIMERO

1. Cualquier padre puede crearse a sí mismo como administrador

Dónde está: app/Http/Controllers/Api/UserController.php (los métodos index, store y toggleStatus).

Qué significa: Esas tres funciones de la API solo revisan que la persona haya iniciado sesión, sin revisar de qué rol es. Se probó de verdad: con la cuenta de un padre normal se creó una cuenta de administrador nueva.

Cómo corregirlo: Agregar una verificación de rol (que solo el admin pueda usar esas tres funciones), igual que ya existe para las páginas web equivalentes.

Qué debo probar de nuevo: Repetir la misma prueba (crear un usuario admin con el token de un padre) y confirmar que ahora se rechaza.

2. Cualquiera puede descargar los datos de todos los estudiantes

Dónde está: routes/web.php y StudentController.php (exportPdfAll/exportExcelAll).

Qué significa: Un padre pudo descargar el PDF y el Excel con los 20 estudiantes del colegio, no solo el suyo.

Cómo corregirlo: Agregar la misma restricción de rol que ya protege el resto de acciones de estudiantes.

Qué debo probar de nuevo: Intentar exportar "todos los estudiantes" con una cuenta de padre y confirmar que se rechaza.

3. Los padres ven a todos los estudiantes, no solo al suyo

Dónde está: StudentController.php, método index().

Qué significa: Falta un filtro para los roles padre/madre/tutor, igual al que ya existe para profesor.

Cómo corregirlo: Agregar ese filtro, usando como modelo el que ya funciona bien en la versión de la API.

Qué debo probar de nuevo: Entrar con una cuenta de padre y confirmar que en "Estudiantes" solo aparece su hijo.

4. Una cuenta desactivada puede seguir entrando

Dónde está: AuthController.php, método login().

Qué significa: El formulario de login no revisa si la cuenta está activa.

Cómo corregirlo: Revisar el estado justo después de comprobar la contraseña, y rechazar el acceso si está inactiva.

Qué debo probar de nuevo: Desactivar una cuenta de prueba e intentar entrar: debe ser rechazada.

5. Los padres nunca ven su propio panel familiar

Dónde está: User.php (método isTutor), TutorController.php, routes/web.php, y DashboardController.php.

Qué significa: El sistema busca usuarios con rol exactamente 'tutor', pero todos los padres reales tienen rol 'padre' o 'madre'. Por eso ven la pantalla equivocada, no pueden entrar a /tutor/dashboard, y la API de 'mis hijos' los rechaza.

Cómo corregirlo: Usar en los 4 lugares la función isResponsibleRole() que ya existe y que sí reconoce padre/madre/tutor juntos.

Qué debo probar de nuevo: Entrar con una cuenta de padre real y confirmar que ve su panel familiar, que puede entrar a /tutor/dashboard, y que la API de sus hijos responde bien.

6. Los padres ven datos familiares de otras familias

Dónde está: FamilyMemberController.php, método index().

Qué significa: La lista de familiares no se filtra por quién inició sesión.

Cómo corregirlo: Agregar el mismo tipo de filtro recomendado para el punto 3.

Qué debo probar de nuevo: Entrar con una cuenta de padre y confirmar que solo ve a su propia familia.

CORREGIR DESPUÉS

- Agregar la traducción faltante del modal "Lanzar Actividad" del robot (clave launch_robot_activity) en español y quechua.
- Conectar las tarjetas "Asistencia de Hoy" y "Retos Lanzados" del dashboard a datos reales, o marcarlas claramente como datos de demostración.
- Traducir al quechua los 6 textos del menú lateral que quedaron en español tras la fusión de Cursos y Paralelos.

MEJORAS OPCIONALES

- Eliminar las vistas que ya no tienen ninguna ruta que las use (register, welcome, courses/create, parallels/create) o volver a enlazarlas si aún se necesitan.
- Actualizar el formulario de courses/create.blade.php para que incluya el campo de nivel educativo, o eliminarlo si ya no se usa.
- Unificar el estilo visual de parallels/edit.blade.php con el resto de la plataforma.
- Limpiar el arreglo $fillable de User.php quitando las columnas que ya no existen (rol, telefono, estado).